組織管理API設計書

メタデータ

- **作成日**: 2026-02-18
- **バージョン**: 1.1.0
- **最終更新**: 2026-02-19
- **担当**: Development Team
- **実装状況**: ✅ 実装済み（100%）

概要

このドキュメントは、組織マスタを管理するためのAPI仕様を定義します。

主な機能

- 組織一覧の取得（検索・フィルタリング・ソート対応）
- 組織詳細の取得
- システム管理者一覧の取得
- 組織の新規作成（関連テーブル自動挿入対応）
- 組織情報の更新
- 組織のアクティブ状態変更
- CSVによる一括ダウンロード
- CSVによる一括アップロード（バッチ処理）

対象ユーザー

- プロバイダー（Provider）: 全機能へのアクセス

📋 API一覧

No	HTTPメソッド	エンドポイント	説明	実装状態	権限
1	GET	/api/v1/provider/organization	組織一覧取得	✅ 実装済み	Provider
2	GET	/api/v1/provider/organization/download-csv	組織CSVダウンロード	✅ 実装済み	Provider
3	POST	/api/v1/provider/organization/upload-csv	組織CSVアップロード	✅ 実装済み	Provider
4	GET	/api/v1/provider/organization/:organizationId	組織詳細取得	✅ 実装済み	Provider
5	GET	/api/v1/provider/organization/:organizationId/system-admins	システム管理者一覧取得	✅ 実装済み	Provider
6	POST	/api/v1/provider/organization	組織新規作成	✅ 実装済み	Provider
7	PUT	/api/v1/provider/organization/:organizationId	組織更新	✅ 実装済み	Provider
8	PATCH	/api/v1/provider/organization/:organizationId/status	組織アクティブ状態更新	✅ 実装済み	Provider
9	GET	/api/v1/provider/organization/:organizationId/certificate	クライアント証明書ダウンロード	✅ 実装済み	Provider

---

1. 組織一覧取得API

概要

組織一覧を取得します。検索、フィルタリング、ソート機能に対応します。

エンドポイント

```
GET /api/v1/provider/organization
```

HTTPメソッド

GET

認証要件

- JWT認証必須
- ロール: Provider

ミドルウェアチェーン

```
router.get('/organization',
  authMiddleware,              // JWT認証
  handleValidationErrors,      // バリデーションエラーハンドリング
  organizationController.getOrganizations
);
```

リクエスト

クエリパラメータ

パラメータ	型	必須	デフォルト	説明
search	string	×	-	組織CD、組織e-mail、代表システム管理者、更新日時で検索
is_active	boolean	×	-	アクティブ状態でフィルタ（true/false）
sort_by	string	×	-	ソート項目（organization_cd, update_at）
sort_order	string	×	asc	ソート順（asc/desc）

リクエスト例

```
GET /api/v1/provider/organization?search=研究所
&is_active=true&sort_by=organization_cd&sort_order=asc
```

レスポンス

成功時（200 OK）


```
{
  "success": true,
  "data": [
    {
      "organizationId": "550e8400-e29b-41d4-a716-446655440000",
      "organizationCd": "maiml_lab_001",
      "organizationDisplayName": "MAIML研究所",
      "organizationEmail": "org@example.com",
      "chiefUserId": "admin@example.com",
      "chiefUserName": "山田太郎",
      "corporationName": "サンプル株式会社",
      "isEntry": 1,
      "isActive": true,
      "contractCapacity": 100,
      "contractedUsers": 50,
      "contractedProjects": 30,
      "updatedAt": "20260218103000"
    }
  ],
  "meta": {
    "timestamp": "2026-02-18T10:30:00Z",
    "requestId": "req_abc123"
  }
}
```


ビジネスロジック

1. **認証チェック**
   - JWT認証でuserIdを取得
   - Providerの権限を確認
2. **フィルタリング**
   - searchパラメータ: 組織CD、組織e-mail、代表システム管理者、更新日時に対して部分一致検索
   - is_activeパラメータ: アクティブ状態でフィルタリング

3. **ソート**
    - sort_byで指定されたフィールドでソート
    - sort_orderで昇順/降順を制御

バリデーション

値チェック

- searchは文字列（指定時）
- is_activeはboolean（指定時）
- sort_byは許可された値（organization_cd, update_at）
- sort_orderは"asc"または"desc"

データベーステーブル

使用テーブル

1. **organization**（主テーブル）
    - organization_id, organization_cd, organization_display_name
    - organization_email, chief_user_id, corporation_id
    - is_entry, is_active
    - create_user_id, create_at, update_user_id, update_at

2. **organization_user**（JOIN）
    - user_name（代表システム管理者名の取得）

3. **corporation**（JOIN）
    - corporation_name（会社名の取得）

セキュリティ

認証・認可

- JWT認証必須
- Providerの権限が必要

入力検証

- SQLインジェクション対策（Parameterized Queries）

---

2. 組織CSVダウンロードAPI

概要

組織一覧をCSV形式でダウンロードします。フィルタ条件を適用できます。

エンドポイント

```
GET /api/v1/provider/organization/download-csv
```

HTTPメソッド

GET

認証要件

- JWT認証必須
- ロール: Provider

リクエスト

クエリパラメータ

パラメータ	型	必須	デフォルト	説明
search	string	×	-	組織CD、組織e-mail、代表システム管理者、更新日時で検索
is_active	boolean	×	-	アクティブ状態でフィルタ
organization_cd	string	×	-	組織CDでフィルタ
organization_display_name	string	×	-	組織表示名でフィルタ
corporation_name	string	×	-	会社名でフィルタ

レスポンス

成功時（200 OK）

Content-Type: `text/csv; charset=utf-8`

ファイル名: `organizations_YYYYMMDDhhmmss.csv`

CSV形式 (UTF-8 BOM付き):

```
organization_cd,organization_display_name,organization_email,chief_user_name,chief_user_email,cor
maiml_lab_001,MAIML研究所,org@example.com,山田太郎,admin@example.com,サンプル株式会
社,100,50,30,1,20260218103000,true
```

---

3. 組織CSVアップロードAPI

概要

CSV形式で組織データを一括登録します。各レコードごとに組織追加ダイアログの「保存」ボタン押下時と同じ処理を実行します。

エンドポイント

```
POST /api/v1/provider/organization/upload-csv
```

HTTPメソッド

POST

認証要件

- JWT認証必須
- ロール: Provider

リクエスト

マルチパートフォームデータ

Content-Type: `multipart/form-data`

フィールド	型	必須	説明
file	File	○	CSVファイル

CSV形式

```
organization_cd,organization_display_name,organization_email,chief_user_name,chief_user_email,cor
maiml_lab_001,MAIML研究所,org@example.com,山田太郎,admin@example.com,サンプル株式会
社,100,50,30,1,,true
```

注意:

- `update_at` はアップロード時に無視されます（ダウンロード専用項目）
- `corporation_name` からcorporation_idを自動解決
- 各レコードごとに以下のテーブルへの挿入が自動実行されます：
    1. organization
    2. organization_user（代表システム管理者）
    3. role（ROLE002: システム管理者）

4. role_permission（4つの機能権限）

レスポンス

成功時（200 OK）

```
{
  "success": true,
  "data": {
    "successCount": 2,
    "failureCount": 0,
    "errors": []
  },
  "meta": {
    "timestamp": "2026-02-18T10:30:00Z",
    "requestId": "req_abc123"
  }
}
```

バリデーションエラー時（200 OK）

```
{
  "success": true,
  "data": {
    "successCount": 0,
    "failureCount": 3,
    "errors": [
      {
        "row": 2,
        "field": "organization_cd",
        "message": "2行目: 組織CDは必須です"
      }
    ]
  },
  "meta": {
    "timestamp": "2026-02-18T10:30:00Z",
    "requestId": "req_abc123"
  }
}
```

バリデーション

必須項目

- organization_cd
- organization_display_name
- organization_email
- chief_user_name
- chief_user_email

型チェック

- is_entry: 0または1
- is_active: true/false/1/0
- contract_capacity: 数値のみ（指定時）
- contract_users: 数値のみ（指定時）
- contract_projects: 数値のみ（指定時）

重複チェック

- organization_cdがCSV内で重複していないこと
- organization_cdがDB内に既存していないこと

外部キーチェック

- corporation_nameがcorporationテーブルに存在すること（指定時）

---

4. 組織詳細取得API

概要

組織IDを指定して、組織の詳細情報を取得します。

エンドポイント

```
GET /api/v1/provider/organization/:organizationId
```

HTTPメソッド

GET

認証要件

- JWT認証必須
- ロール: Provider

リクエスト

パスパラメータ

パラメータ	型	必須	説明
organizationId	UUID	○	組織ID

レスポンス

成功時（200 OK）


```
{
  "success": true,
  "data": {
    "organizationId": "550e8400-e29b-41d4-a716-446655440000",
    "organizationCd": "maiml_lab_001",
    "organizationDisplayName": "MAIML研究所",
    "organizationEmail": "org@example.com",
    "chiefUserId": "admin@example.com",
    "chiefUserName": "山田太郎",
    "corporationName": "サンプル株式会社",
    "isEntry": 1,
    "isActive": true,
```

```
    "updatedAt": "20260218103000"
  },
  "meta": {
    "timestamp": "2026-02-18T10:30:00Z",
    "requestId": "req_abc123"
  }
}
```

エラー時（404 Not Found）

```
{
  "success": false,
  "error": {
    "code": "ORGANIZATION_NOT_FOUND",
    "message": "Organization not found"
  },
  "meta": {
    "timestamp": "2026-02-18T10:30:00Z",
    "requestId": "req_abc123"
  }
}
```

---

5. システム管理者一覧取得API

概要

指定された組織のシステム管理者一覧を取得します（組織編集ダイアログの代表システム管理者選択用）。

エンドポイント

```
GET /api/v1/provider/organization/:organizationId/system-admins
```

HTTPメソッド

GET

認証要件

- JWT認証必須
- ロール: Provider

リクエスト

パスパラメータ

パラメータ	型	必須	説明
organizationId	UUID	○	組織ID

レスポンス

成功時（200 OK）

```
{
  "success": true,
  "data": [
    {
      "userId": "admin@example.com",
      "userName": "山田太郎"
    },
    {
      "userId": "admin2@example.com",
      "userName": "佐藤花子"
    }
  ],
  "meta": {
    "timestamp": "2026-02-18T10:30:00Z",
    "requestId": "req_abc123"
  }
}
```

---

6. 組織新規作成API

概要

新しい組織を作成します。関連する4つのテーブルへの挿入が自動的に実行されます。

エンドポイント

```
POST /api/v1/provider/organization
```

HTTPメソッド

POST

認証要件

- JWT認証必須
- ロール: Provider

リクエスト

リクエストボディ

```
{
  "organizationId": "550e8400-e29b-41d4-a716-446655440000",
  "organizationCd": "maiml_lab_002",
  "organizationDisplayName": "新研究所",
  "organizationEmail": "neworg@example.com",
  "chiefUserName": "田中太郎",
  "chiefUserEmail": "tanaka@example.com",
  "corporationId": "corp-uuid-001",
  "isEntry": 1,
  "isActive": true
}
```

パラメータ	型	必須	デフォルト	説明
organizationId	UUID	○	-	組織ID（UUID）

organizationCd	string	○	-	組織CD（50文字以内）
organizationDisplayName	string	○	-	組織表示名
organizationEmail	string	○	-	組織e-mail
chiefUserName	string	○	-	代表システム管理者名
chiefUserEmail	string	○	-	代表者メールアドレス
corporationId	UUID	×	null	会社ID
isEntry	integer	×	0	二段階認証判定（0または1）
isActive	boolean	×	true	アクティブ状態

レスポンス

成功時（201 Created）


```
{
  "success": true,
  "data": {
    "organizationId": "550e8400-e29b-41d4-a716-446655440000",
    "organizationCd": "maiml_lab_002",
    "organizationDisplayName": "新研究所",
    "organizationEmail": "neworg@example.com",
    "chiefUserId": "tanaka@example.com",
    "chiefUserName": "田中太郎",
    "corporationName": "サンプル株式会社",
    "isEntry": 1,
    "isActive": true,
    "updatedAt": "20260218103000"
  },
  "meta": {
    "timestamp": "2026-02-18T10:30:00Z",
    "requestId": "req_abc123"
  }
}
```


ビジネスロジック

組織作成時に以下のテーブルへの挿入が自動的に実行されます：

1. **organizationテーブル**

- 組織基本情報を挿入

2. **organization_userテーブル**
   - 代表システム管理者を挿入
   - user_id = chiefUserEmail
   - role_cd = ROLE002

3. **roleテーブル**
   - システム管理者ロールを挿入
   - role_cd = ROLE002
   - role_name = "システム管理者"

4. **role_permissionテーブル**
   - 4つの機能権限を挿入
   - 020000: システム管理者メニュー（書込可）
   - 030000: データ管理者メニュー（書込可）
   - 040000: 実験管理者メニュー（書込可）
   - 050000: 実験作業者メニュー（書込可）

---

7. 組織更新API

概要

既存の組織情報を更新します。

エンドポイント

```
PUT /api/v1/provider/organization/:organizationId
```

HTTPメソッド

PUT

認証要件

- JWT認証必須
- ロール: Provider

リクエスト

パスパラメータ

パラメータ	型	必須	説明
organizationId	UUID	○	組織ID

リクエストボディ

```
{
  "organizationDisplayName": "MAIML研究所（更新）",
  "organizationEmail": "updated@example.com",
  "chiefUserId": "admin2@example.com",
  "corporationId": "corp-uuid-002",
  "isEntry": 1,
  "isActive": true
}
```

注意: organizationCdは更新不可です（編集ダイアログで非活性）

レスポンス

成功時（200 OK）

```
{
  "success": true,
  "data": {
    "organizationId": "550e8400-e29b-41d4-a716-446655440000",
    "organizationCd": "maiml_lab_001",
```

```
    "organizationDisplayName": "MAIML研究所（更新）",
    "organizationEmail": "updated@example.com",
    "chiefUserId": "admin2@example.com",
    "chiefUserName": "佐藤花子",
    "corporationName": "新会社名",
    "isEntry": 1,
    "isActive": true,
    "updatedAt": "20260218110000"
  },
  "meta": {
    "timestamp": "2026-02-18T11:00:00Z",
    "requestId": "req_abc123"
  }
}
```

---

8. 組織アクティブ状態更新API

概要

組織のアクティブ状態のみを更新します。

エンドポイント

```
PATCH /api/v1/provider/organization/:organizationId/status
```

HTTPメソッド

PATCH

認証要件

- JWT認証必須
- ロール: Provider

リクエスト

パスパラメータ

パラメータ	型	必須	説明
organizationId	UUID	○	組織ID

リクエストボディ

```
{
  "isActive": false
}
```

レスポンス

成功時（200 OK）

```
{
  "success": true,
  "data": {
    "organizationId": "550e8400-e29b-41d4-a716-446655440000",
    "organizationCd": "maiml_lab_001",
    "organizationDisplayName": "MAIML研究所",
    "organizationEmail": "org@example.com",
    "chiefUserId": "admin@example.com",
    "chiefUserName": "山田太郎",
    "corporationName": "サンプル株式会社",
    "isEntry": 1,
    "isActive": false,
    "updatedAt": "20260218110000"
  },
  "meta": {
    "timestamp": "2026-02-18T11:00:00Z",
    "requestId": "req_abc123"
  }
}
```

---

9. クライアント証明書ダウンロードAPI

概要

組織のクライアント証明書（PKCS#12形式）をダウンロードします。組織作成時に自動生成された証明書をSwift/S3から取得します。

エンドポイント

```
GET /api/v1/provider/organization/:organizationId/certificate
```

HTTPメソッド

GET

認証要件

- JWT認証必須
- ロール: Provider

ミドルウェアチェーン

```
router.get(
  '/organization/:organizationId/certificate',
  authMiddleware,
  [
    param('organizationId')
      .notEmpty()
      .withMessage('organizationId is required')
      .isUUID()
      .withMessage('organizationId must be a valid UUID'),
  ],
  handleValidationErrors,
  organizationController.downloadCertificate
);
```

リクエスト

パスパラメータ

パラメータ	型	必須	説明
organizationId	UUID	○	組織ID

リクエスト例

```
GET /api/v1/provider/organization/550e8400-e29b-41d4-a716-446655440000/certificate
```

レスポンス

成功時（200 OK）

Content-Type: `application/x-pkcs12` **Content-Disposition**: `attachment; filename="{organizationId}.p12"`

ファイル形式: PKCS#12（バイナリデータ） **ファイルサイズ**: 約4-6KB

証明書の内容:

- **クライアント秘密鍵**: RSA 2048bit
- **クライアント証明書**: 有効期限1年、組織IDをCNに設定
- **CA証明書**: 証明書チェーン（10年有効）

パスワード:

- デフォルト: `mmdpf123`
- 環境変数 `CERT_P12_PASSWORD` で変更可能

エラー時（404 Not Found）

```
{
  "success": false,
```

```
  "error": {
    "code": "CERTIFICATE_NOT_FOUND",
    "message": "証明書が見つかりません"
  },
  "meta": {
    "timestamp": "2026-02-19T09:00:00Z",
    "requestId": "req_abc123"
  }
}
```

ビジネスロジック

1. **認証チェック**
   - JWT認証でuserIdを取得
   - Providerの権限を確認
2. **証明書取得**
   - certificateService.getCertificateFromStorage() を呼び出し
   - Swift/S3から証明書ファイルを取得
   - パス: `{organizationId}/certificates/{organizationId}.p12`
3. **レスポンス生成**
   - Content-Typeを `application/x-pkcs12` に設定
   - Content-Dispositionでファイル名を指定
   - バイナリデータを送信

バリデーション

パラメータチェック

- organizationIdは必須
- organizationIdはUUID形式である必要あり

存在確認

- 組織がデータベースに存在すること
- 証明書ファイルがSwift/S3に存在すること

データベーステーブル

使用テーブル:

- **organization**（組織の存在確認）

ストレージ:

- **Swift/S3**: `{organizationId}/certificates/{organizationId}.p12`

証明書の使用方法

ブラウザへのインポート

Firefox:

1. 設定 → プライバシーとセキュリティ → 証明書 → 証明書を表示
2. あなたの証明書 → インポート
3. ダウンロードした.p12ファイルを選択
4. パスワード（mmdpf123）を入力

Chrome/Edge:

1. 設定 → プライバシーとセキュリティ → セキュリティ → 証明書の管理
2. 個人 → インポート
3. ダウンロードした.p12ファイルを選択
4. パスワード（mmdpf123）を入力

クライアント証明書認証

インポートした証明書は以下の用途で使用できます：

- クライアント証明書認証が必要なWebサイトへのアクセス
- セキュアなAPI通信

- VPN接続

セキュリティ

証明書の保護

- PKCS#12ファイルはパスワードで暗号化
- パスワードは環境変数で管理（本番環境では強力なパスワードに変更推奨）
- 証明書の有効期限は1年（定期的な更新が必要）

アクセス制御

- Provider権限のユーザーのみダウンロード可能
- 組織がアクティブ状態でなくてもダウンロード可能（証明書再発行のため）
- Swift/S3のマルチテナント分離により他組織の証明書にはアクセス不可

監査ログ

- ダウンロード操作はアプリケーションログに記録
- 組織ID、ユーザーID、タイムスタンプを含む

関連機能

証明書の自動生成

- 組織作成時（POST /api/v1/provider/organization）に自動的に証明書を生成
- organizationService.createOrganization() → certificateService.generateAndSaveCertificate()
- 生成失敗時も組織作成は成功（後から再生成可能）

証明書の再生成

- 証明書生成失敗や更新が必要な場合、再生成スクリプトを使用
- コマンド: `npx ts-node backend/scripts/regenerate-certificate.ts {organizationId}`

🔗 関連ドキュメント

API設計書

- api_list.md - API一覧対応表
- api_corporation_management.md - 会社管理API
- api_department_management.md - 部署管理API
- api_master_management.md - マスタ管理API
- api_role_management.md - ロール管理API

規約・ガイドライン

- バックエンド規約 - 実装規約
- セキュリティ規約 - セキュリティ要件

📊 実装ファイルパス

ルートファイル

```
backend/src/routes/organizationRoutes.ts
```

コントローラーファイル

```
backend/src/controllers/organizationController.ts
```

サービスファイル

```
backend/src/services/organizationService.ts
```

リポジトリファイル

```
backend/src/repositories/organizationManagementRepository.ts
```

フロントエンドコンポーネント

```
frontend/src/components/Provider/OrganizationManagement.tsx
```

✅ セキュリティチェックリスト

実装時に以下を確認してください：

認証・認可

- [x] すべてのエンドポイントでJWT認証が必須
- [x] authMiddlewareが適用されている
- [x] Providerの権限が必要

入力検証

- [x] すべてのパラメータがバリデーションされている
- [x] Parameterized Queriesを使用（SQLインジェクション対策）
- [x] XSS対策（入力サニタイゼーション）
- [x] 文字列長制限が強制されている（organizationCd: 50文字）

CSVアップロード対策

- [x] ファイルサイズ制限（10MB）
- [x] 許可されたMIMEタイプのみ（text/csv）
- [x] ファイル内容のバリデーション
- [x] CSVインジェクション対策

エラーハンドリング

- ☑ 統一されたエラーレスポンス形式
- ☑ エラーメッセージに機密情報が含まれない
- ☑ 適切なHTTPステータスコードを返す

トランザクション管理

- ☑ 組織作成時に4テーブルへの挿入がトランザクション保証されている
- ☑ エラー時に自動的にROLLBACKされる

📝 変更履歴

バージョン	日付	変更内容	担当者
1.2.0	2026-03-05	契約情報3項目追加	Cline
		- 組織一覧レスポンスに contractCapacity / contractedUsers / contractedProjects 追加	
		- CSVダウンロード・アップロードの列定義に contract_capacity / contract_users / contract_projects 追加	
		- CSVアップロードバリデーションに数値チェック追加	
1.1.0	2026-02-19	クライアント証明書ダウンロードAPI追加	Cline
		- API #9: GET /organization/:organizationId/certificate 追加	
		- PKCS#12形式の証明書ダウンロード機能	
		- 組織作成時に自動生成された証明書を取得	
		- certificateService統合	
		- 実装済み（9/9エンドポイント、100%）	
1.0.0	2026-02-18	初版作成	Cline
		- 組織管理API 8エンドポイントの設計書作成	

		- 実装済み（100%）	
		- CSVアップロード機能：組織追加ダイアログと同じ処理を実行	
		- 関連テーブル自動挿入機能（organization, organization_user, role, role_permission）	

注意: この設計書は実装済みAPIの仕様を文書化したものです。実装の詳細については、実際のソースコード（backend/src/routes/organizationRoutes.ts等）を参照してください。